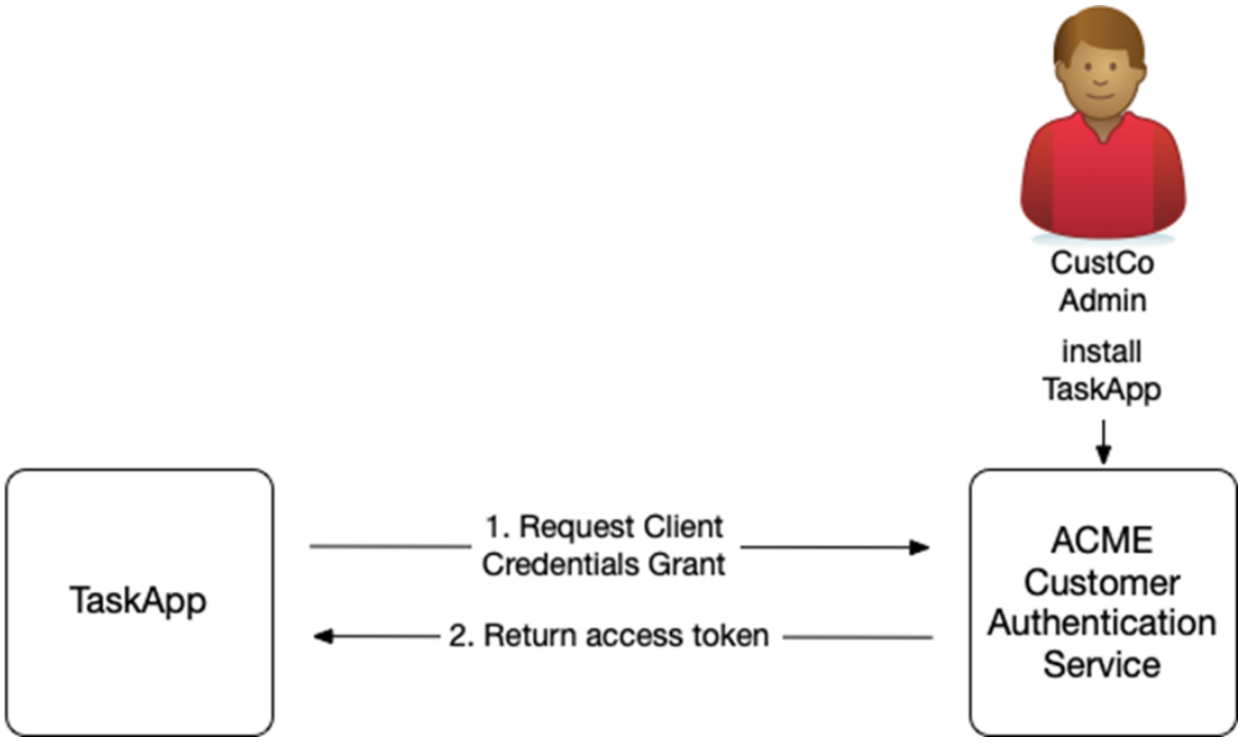


Figure 11.7 CustCo's Task App authenticates to ACME's authorization server using its client credentials and receives an access token that represents the app (an integration principal). Admin setup and the installation record bind the app to CustCo and specific workspaces.

By the end of this process, the Task App holds a valid access token that represents the application itself. This token is all it needs to start making API calls on behalf of CustCo. Since access tokens are short-lived, the app repeats this process as needed. How the token is validated, enriched with installation details, and combined with Cedar policies is explained in the next section on using tokens.

OTHER OAUTH GRANTS

OAuth specifies a few additional ways for clients to get tokens, although they are less often recommended today. I include them here for completeness:

- **Implicit Grant.** Originally intended for browser-based single-page apps, the implicit flow bypassed the authorization code step and returned an access token directly in the URL fragment. This saved an additional network request but increased the risk of token leakage. Today, implicit is considered insecure and has largely been replaced by